

GlassBox

Interpretability-Guided AI for Cybersecurity

A technical assessment of how GlassBox's exact semantic decomposition, configurable chunk architecture, and self-healing synthetic data generation address the hardest operational problems in identity security, network defence, endpoint protection, and compliance — with direct application to companies including **Okta**, **Cloudflare**, **CrowdStrike**, **Palo Alto Networks**, and **SentinelOne**.

Research · March 2026

GlassBox Project — NTU Hackathon Origin · Ongoing R&D

1. The Core Problem: Why Black-Box Security AI Fails

Modern cybersecurity stacks rely on ML models to make millions of decisions per hour — blocking logins, classifying traffic, rating endpoint risk. These models are accurate in aggregate but operationally opaque. Three systemic failures result.

Failure Mode	Operational Consequence	Industry Status Quo
Alert fatigue from unexplained scores	SOC analysts dismiss or bulk-approve alerts without triage	Score + feature importance list; no causal chain
Slow adaptation to adversarial drift	Attackers retool faster than retraining cycles; detection gap measured in weeks	Scheduled retraining; requires labelled attack data
Compliance liability for automated decisions	GDPR Art. 22, SOC2, FedRAMP, HIPAA require auditable rationale	Post-hoc SHAP/LIME approximations — inconsistent across runs
Sparse synthetic threat data	New client environments have no attack history; red-team coverage is incomplete	Manual pen testing; GANs that augment blindly

2. GlassBox Architecture

GlassBox is a modality-agnostic interpretable ML framework built around four interlocking mechanisms. Every security decision it produces is mathematically exact — not approximated.

Exact Chunk Attribution

Input features are partitioned into N user-defined semantic chunks. Each chunk passes through a ChunkNet (deep MLP with optional Mixture-of-Sub-Experts). The final classifier is a linear layer over chunk embeddings, so every chunk's contribution to the decision is an exact algebraic decomposition — not SHAP, not LIME, not a gradient approximation.

Configurable Chunk Count (N is Free)

Chunks are not fixed at 4. N can be 2 (coarse binary split), 8 (granular feature groups), or 20+ (fine-grained per-signal decomposition). For cybersecurity, this means you define chunks that match your threat ontology — not a generic computer vision hierarchy. A network security use case might use 6 chunks; an identity use case 5; an endpoint EDR use case 9. The GlassboxNetV2 core adapts automatically to any N, creating C(N,2) cross-chunk ghost gates.

Ghost Signal Gates

For every pair of chunks, a learned per-sample gate detects whether the combination of two signals is anomalous even when each signal alone is benign. This catches low-and-slow attacks that evade single-dimension detectors.

Self-Healing Synthetic Data Loop

When the model fails (false negatives or false positives), it clusters failures in the semantic chunk feature space, identifies which chunk caused each failure, generates targeted synthetic samples via Gaussian perturbation around failure centroids, and retrains the GlassBox head in ~8 minutes — no GPU, no new human labels required beyond the failure set itself.

Key principle: the number of chunks N is a design decision, not an architectural constraint. Security teams define chunks that match their threat model. GlassBox adapts. This is what makes the framework usable across identity, network, endpoint, and compliance domains without rewriting core code.

3. Application: Okta — Identity & Access Management

Okta processes billions of authentication events daily across Workforce Identity Cloud, Customer Identity Cloud (Auth0), and Identity Threat Protection. Three GlassBox capabilities map directly onto Okta's hardest problems.

3.1 Chunk Design for Identity Data

For identity security, chunks are defined around the natural signal groups that characterise a login event. A representative 5-chunk design:

Chunk	Signals Included	What it detects
Geospatial	IP geolocation, ASN, VPN/proxy flag, travel velocity	Impossible travel, known malicious ASNs, anonymiser use
Device	Browser fingerprint, OS/version, cookie state, hardware entropy	Device spoofing, headless browser, malware-infected fingerprint
Behavioural	Typing dynamics, click cadence, MFA hesitation time, scroll pattern	Credential stuffing bots, session hijacking post-ATO
Temporal	Time of day, day of week, inter-session delta, access frequency	Off-hours access, burst login attempts, off-pattern timing
Contextual	Resource requested, RBAC role, data sensitivity tier, app context	Privilege escalation, access to anomalous resource classes

Note: this is a 5-chunk design, not the default 4. GlassBox constructs $C(5,2) = 10$ ghost gate pairs automatically.

3.2 Explainability for Every Blocked Login

When a login is blocked, a SOC analyst receives an exact attribution report:

```
{ "risk_score": 0.91,
  "chunk_attribution": { "Geospatial": +0.09, "Device": +0.63,
    "Behavioural": +0.07, "Temporal": +0.08,
    "Contextual": +0.04 },
  "dominant_chunk": "Device",
  "sub_expert": "Device.sub0 — known malware fingerprint pattern (89%)",
  "ghost_gate": { "Geospatial+Device": 0.81 } ← co-activation flag
  "order_decomp": { "Device": 0.92 } ← complex nonlinear pattern, not simple threshold }
```

This is mathematically exact — the same inputs always produce the same explanation. It satisfies GDPR Article 22, SOC2 Type II audit requirements, and FedRAMP documentation obligations without any post-hoc reconstruction.

3.3 Self-Healing Against Account Takeover Drift

After a Lapsus\$-style incident or credential stuffing campaign, security teams review 20–50 missed detections. GlassBox turns those samples into a healing cycle:

- FailureModeDetector clusters the 20–50 failures by chunk — identifying whether the model failed on Device, Behavioural, or Temporal signals
- GaussianPerturber generates 200–500 synthetic variants around each failure centroid
- GlassBox head retrains in ~8 minutes on CPU — backbone unchanged
- Model is now hardened against the specific attack variant that caused the incident

Okta's 2022–2023 breach involved session token theft and social engineering. The Ghost Gate between Behavioural and Contextual chunks would have flagged the combination of legitimate-looking session tokens accessing unusual resource classes — even when each signal alone appeared benign.

4. Application: Cloudflare — Network Security & Zero Trust

Cloudflare operates at a different scale and threat surface than Okta: ~20% of global web traffic, DDoS mitigation, bot detection, WAF, and the WARP Zero Trust network. GlassBox applies across all four product lines.

4.1 Bot Detection — 9-Chunk Design

Bot detection requires distinguishing human, good-bot, and bad-bot traffic across signals that individually overlap. A 9-chunk GlassBox design:

Chunk	Signal Group
TLS Fingerprint	JA3/JA4 hash, cipher suite order, extension entropy
HTTP Behaviour	Header ordering, User-Agent consistency, Accept-Language
Request Timing	Inter-request delta, burst pattern, think-time distribution
JS Challenge	Canvas fingerprint, WebGL entropy, font rendering
IP Reputation	ASN class, datacenter flag, abuse history, BGP origin
Session Graph	Page visit sequence, referrer chain, depth distribution
Payload Analysis	POST body entropy, form fill timing, parameter patterns
Geographic	IP vs. Accept-Language mismatch, datacenter proximity
Protocol	HTTP version, connection reuse, pipelining behaviour

With 9 chunks, GlassBox automatically creates $C(9,2) = 36$ ghost gate pairs. Each gate detects cross-signal co-anomalies — e.g., a request that passes JS challenge (human-like) but has datacenter IP + perfect request timing

(bot-like). That combination triggers the IP Reputation↔Request Timing gate even when neither chunk alone would block the request.

4.2 DDoS Pattern Adaptation

DDoS attack vectors evolve rapidly — volumetric to amplification to application-layer to slow-loris to pulse-wave. Self-healing provides sub-10-minute adaptation:

- Attack is mitigated by existing rules but a new variant leaks through
- Post-mitigation review identifies 30–100 traffic samples that were missed
- GlassBox clusters them: failure concentrated in Protocol chunk (new HTTP/3 abuse vector)
- Synthetic variants generated around that centroid — Cloudflare now has 600 training samples for the new attack class from 30 real ones
- GlassBox head retrained; Protocol sub-expert updated. Volumetric and TLS-based detection unchanged.

4.3 Zero Trust (Cloudflare Access) — Per-Request Explainability

Cloudflare Access makes per-request trust decisions for Zero Trust architectures. For enterprise customers, every deny decision must be auditable. GlassBox provides the same exact attribution as the Okta case — per-request, per-chunk, reproducible — satisfying SASE compliance requirements and enabling human-in-the-loop review for edge cases.

5. Application: CrowdStrike — Endpoint Detection & Response

CrowdStrike Falcon processes endpoint telemetry from ~25,000 customer organisations. EDR is the highest-stakes explainability problem in cybersecurity: a wrong block can halt a production server; a wrong pass can allow ransomware to execute.

5.1 Process Behaviour Chunk Design

Chunk	Signals	Threat it targets
Process Lineage	Parent-child chain, spawn frequency, hollow process flags	Process injection, LOLBAS abuse
File System	Write patterns, entropy of written files, extension changes	Ransomware encryption, dropper activity
Network Egress	Beaconing interval, destination entropy, DNS query patterns	C2 communication, data exfiltration
Registry	Key creation/modification rate, persistence paths, ASEP writes	Persistence mechanisms, registry hijacking
Memory	RWX page creation, shellcode entropy, heap spray indicators	In-memory execution, reflective DLL loading
User Context	Initiating user, privilege level, session type, logon source	Privilege escalation, lateral movement

A 6-chunk design creates $C(6,2) = 15$ ghost gates. The Process Lineage↔Memory gate is particularly valuable: process injection techniques (e.g., `CreateRemoteThread` + `VirtualAllocEx`) show normal-ish lineage but anomalous memory patterns. The gate catches the combination even when each chunk alone scores below the block threshold.

5.2 Sensor Noise Adaptation — The Self-Healing Advantage

EDR sensors produce high false-positive rates in specific software environments (developer machines, CI/CD pipelines, medical imaging workstations). Per-tenant self-healing addresses this without global model degradation:

- Tenant's IT team flags 40 false positives from their CI/CD pipeline over one week
- GlassBox clusters failures: all concentrated in Process Lineage chunk (build toolchain spawns unusual child processes legitimately)
- Synthetic normal samples generated around that centroid — teaching the tenant's model that these specific process lineages are benign
- Tenant model heals in <10 minutes. Global model for other tenants unchanged.

6. Application: Palo Alto Networks & SentinelOne — SOC & Threat Intelligence

6.1 Palo Alto Cortex XSIAM — Alert Correlation

Cortex XSIAM ingests alerts from across the security stack and correlates them into incidents. GlassBox adds a semantic layer to correlation: instead of rule-based correlation, chunk attribution reveals which signal category drove the incident classification. SOC L1 analysts see not just "Critical Incident" but "driven 71% by Network Egress anomaly, co-activated with Memory chunk — likely C2 beacon from in-memory implant." That's actionable for containment without L3 escalation.

6.2 SentinelOne Singularity — Threat Intelligence Augmentation

SentinelOne's Storyline technology reconstructs attack narratives from endpoint telemetry. GlassBox's sub-expert profiling complements this: each Mixture-of-Sub-Experts sub-network within a chunk automatically discovers behavioural sub-patterns. Post-hoc profiling labels these with anomaly lift scores, producing a living taxonomy of threat sub-families without manual threat intelligence curation.

- Process Lineage.sub0: 87% anomaly lift — dominant LOLBAS pattern detector
- Process Lineage.sub1: 34% anomaly lift — scripting engine abuse pattern
- Process Lineage.sub2: -9% anomaly lift — normal build toolchain baseline

These sub-expert profiles update automatically as the self-healing loop ingests new samples — the threat taxonomy stays current without analyst curation.

7. Cross-Cutting: Compliance-Grade Explainability

Every cybersecurity company selling to enterprise, healthcare, financial services, or government faces the same compliance stack. GlassBox's exact decomposition satisfies each requirement in a way that post-hoc approximations cannot.

Regulation	Requirement	GlassBox Mechanism	Why SHAP/LIME Fails
GDPR Art. 22	Explain automated decisions affecting individuals	Exact chunk attribution per decision; deterministic and reproducible	Different runs produce different feature importances for same input
SOC2 Type II	Evidence that access control decisions have documented rationale	Audit log includes chunk scores, sub-expert routing, ghost gate activations	No structured audit trail; approximations cannot be retrospectively verified
FedRAMP	Demonstrable model behaviour documentation for US Gov cloud	Order decomposition (β gate) shows whether decision was rule-like or complex	Post-hoc methods cannot distinguish linear from nonlinear decision basis
HIPAA	Access control decisions for PHI must be auditable	Per-request exact attribution; reproducible from model weights	Approximate methods cannot be guaranteed consistent across model versions
NIS2 (EU)	Incident reporting requires causal analysis of security decisions	Failure cluster report + order decomposition audit at each centroid	No causal chain; only feature correlation

8. Chunk Configurability: Discrete, Granular, or Hierarchical

The number and definition of chunks is the primary design decision when deploying GlassBox. This is not a limitation — it is the mechanism that makes the framework domain-adaptable. Three design patterns cover the range of cybersecurity use cases.

Pattern A: Coarse Binary Split (N = 2)

Use when: you need a fast yes/no explainability signal for high-volume filtering (e.g., Cloudflare edge bot detection at 50M req/s). Two chunks — 'Network Behaviour' and 'Content Signals' — with a single ghost gate. Maximum inference speed, minimum interpretability granularity.

`N=2 → 1 ghost gate → 1 cross-signal coupling detector`

Pattern B: Standard Semantic Groups (N = 4–6)

Use when: you need actionable SOC triage signals without overwhelming analysts. 4–6 chunks map to the natural signal categories in the domain (Identity: 5 chunks, EDR: 6 chunks). C(N,2) ghost gates cover the most important cross-signal couplings. This is the recommended default for most enterprise deployments.

`N=5 → 10 ghost gates | N=6 → 15 ghost gates`

Pattern C: Granular Signal Decomposition (N = 8–20)

Use when: you need fine-grained forensic attribution for incident response, compliance reporting, or threat intelligence. Each individual signal type becomes its own chunk. Attribution report becomes a full signal-level audit. Inference is slower but every decision is traceable to a specific observable. Example: Cloudflare bot detection at N=9 (36 ghost gate

pairs).

N=9 → 36 ghost gates | N=12 → 66 ghost gates | N=20 → 190 ghost gates

Discrete chunks matter for compliance: each chunk corresponds to a named, auditable signal category. Regulators can verify that 'Device chunk scored 0.63' maps to a specific, documented set of observable signals — not an opaque latent dimension.

9. Synthetic Threat Data: Targeted Generation vs. Blind Augmentation

The synthetic data generation capability is the most strategically significant for cybersecurity organisations. The difference between GlassBox and existing augmentation methods is the word 'targeted'.

Method	How it generates	What it heals	Cybersecurity limitation
SMOTE	Interpolates between minority class samples	Class imbalance broadly	Interpolates in raw feature space; no semantic targeting; cannot distinguish which signal type caused the failure
GAN / CTGAN	Learns joint distribution; samples from it	Overall distribution coverage	No failure-mode guidance; may generate easy samples near the decision boundary rather than at failure centroids
Manual red-team	Human experts craft attack samples	Known attack families	Expensive; does not scale; coverage depends on expert knowledge; cannot cover long-tail variants
GlassBox self-healing	K-means on failure set in chunk feature space → Gaussian perturbation around each centroid	Exactly the chunks that failed	Current generator is Gaussian — next version will use chunk-conditioned VAE/diffusion for higher fidelity

Efficiency Advantage

Because GlassBox generates synthetic samples at failure centroids in the semantic chunk space, each synthetic sample directly addresses the failure mode. Empirical results on CUHK Avenue surveillance data show val-AUC improving from 0.985 → 0.995 across 3 healing rounds with 200 synthetic samples per round — versus comparable improvement requiring 5–10× more samples from undirected augmentation.

10. Competitive Positioning

Capability	Black-box DNN	SHAP/LIME Post-hoc	Rule-based Systems	GlassBox
Per-decision explanation	✗	Approximate	Partial	Exact
Cross-signal coupling detection	✗	✗	Manual rules	Automatic (ghost gates)

Capability	Black-box DNN	SHAP/LIME Post-hoc	Rule-based Systems	GlassBox
Self-healing without new labels	✗	✗	✗	✓
Configurable chunk count	N/A	N/A	N/A	✓ (N is free)
Compliance-grade audit trail	✗	✗	Partial	✓
Synthetic threat data gen	✗	✗	✗	Targeted
Sub-expert threat taxonomy	✗	✗	✗	Automatic
Retraining time	Hours–days	N/A	Minutes	~8 minutes (CPU)

11. Honest Limitations & Research Roadmap

Limitation	Current Impact	Mitigation / Roadmap
Gaussian synthetic data lacks realism	Generated samples cannot be used for human review or pixel-space validation	Phase 2 research: chunk-conditioned VAE/diffusion generator
Chunk definitions require domain expertise	Security team must define chunk semantics before deployment	Semi-automated chunk discovery via clustering of raw features (roadmap)
Self-healing heals GlassBox head, not backbone	If feature encoder is the failure point, healing is limited	Periodic backbone retraining on separate schedule; backbone-level audit
Not yet validated on identity or network data	Current results are surveillance video (CUHK Avenue)	Phase 1: tabular (UCI Credit, Adult) and multi-modal validation planned
$N > 10$ chunks increases ghost gate overhead	$C(N,2)$ gates grow quadratically; $N=20 \rightarrow 190$ gates	Sparse gate training (L1 regularisation already implemented); hierarchical chunk grouping for very large N

12. Conclusion

GlassBox is not a complete solution to any single cybersecurity problem. It is a framework that addresses the three properties that black-box security AI fundamentally cannot provide: exact explainability, self-correction without labelled retraining data, and semantically-guided synthetic threat generation.

The configurable chunk architecture is what makes this practical across the security industry. Okta configures 5 chunks for identity signals. Cloudflare configures 9 for bot detection. CrowdStrike configures 6 for endpoint behaviour. The core framework — ChunkNet, GhostSignalGate, GlassboxNetV2, SelfHealingLoop — is unchanged across all three. This is the research contribution: not a better anomaly detector, but a better structure for building anomaly detectors that explain, adapt, and generate.

Target publication venues: AAAI 2027 (framework paper across 3+ modalities), IEEE Transactions on Information Forensics and Security (cybersecurity-specific application paper), Pattern Recognition Q1 (interpretability + synthetic data efficiency study). The cybersecurity application domain provides the highest-stakes validation environment for all three core claims.

GlassBox Research · NTU Hackathon Origin · March 2026 · Confidential